Oracle Aggregator

Security Review

Cantina Managed review by:

High Byte, Security Researcher
Om Parikh, Security Researcher

January 14, 2025

Contents

1 Introduction **2**
- 1.1 About Cantina . . . 2
- 1.2 Disclaimer . . . 2
- 1.3 Risk assessment . . . 2
  - 1.3.1 Severity Classification . . . 2

2 Security Review Summary **3**

3 Findings **4**
- 3.1 Low Risk . . . 4
  - 3.1.1 Inconsinstent decimals adjusted value retruned from aggregator in case of non-USD denominated price feed . . . 4
- 3.2 Gas Optimization . . . 4
  - 3.2.1 Small gas opt . . . 4
- 3.3 Informational . . . 4
  - 3.3.1 Missing natspec . . . 4
  - 3.3.2 Passing fixed gas in oracle reads may not work in futrure hardfork . . . 4

DRAFT

1 Introduction

1.1 About Cantina

Cantina is a security services marketplace that connects top security researchers and solutions with clients. Learn more at cantina.xyz

1.2 Disclaimer

Cantina Managed provides a detailed evaluation of the security posture of the code at a particular moment based on the information available at the time of the review. While Cantina Managed endeavors to identify and disclose all potential security issues, it cannot guarantee that every vulnerability will be detected or that the code will be entirely secure against all possible attacks. The assessment is conducted based on the specific commit and version of the code provided. Any subsequent modifications to the code may introduce new vulnerabilities that were absent during the initial review. Therefore, any changes made to the code require a new security review to ensure that the code remains secure. Please be advised that the Cantina Managed security review is not a replacement for continuous security measures such as penetration testing, vulnerability scanning, and regular code reviews.

1.3 Risk assessment

Severity	Description
Critical	*Must* fix as soon as possible (if already deployed).
High	Leads to a loss of a significant portion (>10%) of assets in the protocol, or significant harm to a majority of users.
Medium	Global losses <10% or losses to only a subset of users, but still unacceptable.
Low	Losses will be annoying but bearable. Applies to things like griefing attacks that can be easily repaired or even gas inefficiencies.
Gas Optimization	Suggestions around gas saving practices.
Informational	Suggestions around best practices or readability.

1.3.1 Severity Classification

The severity of security issues found during the security review is categorized based on the above table. Critical findings have a high likelihood of being exploited and must be addressed immediately. High findings are almost certain to occur, easy to perform, or not easy but highly incentivized thus must be fixed as soon as possible.

Medium findings are conditionally possible or incentivized but are still relatively likely to occur and should be addressed. Low findings a rare combination of circumstances to exploit, or offer little to no incentive to exploit but are recommended to be addressed.

Lastly, some findings might represent objective improvements that should be addressed but do not impact the project's overall security (Gas and Informational findings).

DRAFT

2 Security Review Summary

RedStone Oracles is a leading oracle provider that provides customizable and cost-efficient data streams for builders empowering the next generation of dApps.

From Jan 11th to Jan 14th the Cantina team conducted a review of oracle-aggregator on commit hash 336a8356. The team identified a total of **4** issues:

Issues Found

Severity	Count	Fixed	Acknowledged
Critical Risk	0	0	0
High Risk	0	0	0
Medium Risk	0	0	0
Low Risk	1	0	0
Gas Optimizations	1	0	0
Informational	2	0	0
Total	**4**	**0**	**0**

DRAFT

3 Findings

3.1 Low Risk

3.1.1 Inconsinstent decimals adjusted value retruned from aggregator in case of non-USD denominated price feed

Severity: Low Risk

Context: *(No context files were provided by the reviewer)*

Description: `_safeLatestRoundData` assumes chainlink returned value is in 8 decimals which is not always true.

As per chainlink documentation, `AggregatorV3Interface(feed).decimals();` should be used to query precision of respective feed.

This is especially required in non USD denominated feeds.

Recommendation: Ensure decimals are always adjusted to 8 irrespective of underlying chainlink price feed's decimals by scaling.

3.2 Gas Optimization

3.2.1 Small gas opt

Severity: Gas Optimization

Context: OracleAggregator.sol#L117

Description: This arithmetic expression is not optimized and is recalculated every time, even though all 3 values are const. it can be optimized to a simple division by const: `1e8`.

Recommendation: Cache the value in const.

3.3 Informational

3.3.1 Missing natspec

Severity: Informational

Context: *(No context files were provided by the reviewer)*

Description:

- `NumericArrayLib` is missing natspec on functions. several things such as `sort` sorts in descending order should be documented.
- `ETH_Oracle_Aggregated_Chronicle_Chainlink_Redstone` should have some basic natspec/documentation `getAgeThreshold`, `checkAuthorisedDataConsumer`, etc...
- Several functions which revert or return hardcoded values in `OracleAggregator` doesn't have natspec to explain the reasoninig.

Recommendation: Add appropriate natspec / documentation.

3.3.2 Passing fixed gas in oracle reads may not work in futrure hardfork

Severity: Informational

Context: *(No context files were provided by the reviewer)*

Description: In `OracleAggregator`, fixed gas units (`_GAS_LIMIT_PER_ORACLE_READ`) is passed for reading the data, which could impact negatively if future ethereum hardforks reprice opcodes and price of `SLOAD` is increased.

Recommendation:

- Document this explicity that in such case a new oracle would be deployed.
- Pass dynamic gas limit.

DRAFT